

Lab 1: IoC, TTP i cicle d'intel·ligència

Detecció d'amengaces

GEI | FIB | Curs 2026/2027



UNIVERSITAT POLITÈCNICA DE CATALUNYA
BARCELONATECH

Facultat d'Informàtica de Barcelona



UNIVERSITAT POLITÈCNICA DE CATALUNYA
BARCELONATECH

Facultat d'Informàtica de Barcelona

Detecció d'amengaces

Assignatura amb 22 hores de laboratori corresponent a l'especialitat:

Tecnologies de la informació

Incloua en el:

Grau en Enginyeria Informàtica



Sobre mi

- **MANEL RODERO**

- Administrador de Sistemes, [Universitat Politècnica de Catalunya](#):
 - [UTGCNTIC](#) [2019 – actualitat]
 - [inLab FIB](#) [2012 – 2019]
 - LCFIB [1996 – 2012]
- Analista de Seguretat, [esCERT-UPC](#) [2013 – 2017]
- Enginyer Informàtic, [Facultat d'Informàtica de Barcelona](#) [1999]
- Contacte:
 - manel.rodero@upc.edu

Lab 1. IoC, TTP i cicle d'intel·ligència

Identificar actors d'amengaces i fonaments de CTI



Què és la CyberThreat Intelligence (CTI)?

- Informació **processada**, **contextualitzada** i **analitzada** sobre amenaces informàtiques
- Permet passar d'una defensa **reactiva** (esperar l'atac) a una de **proactiva** (anticipar-lo)
- No és "*només dades*" és ...
 - **Dada** (observació raw)
 - **Context** (qui, quan, per què)
 - **Anàlisi** (interpretació)
 - **Coneixement accionable** (mesura defensiva)

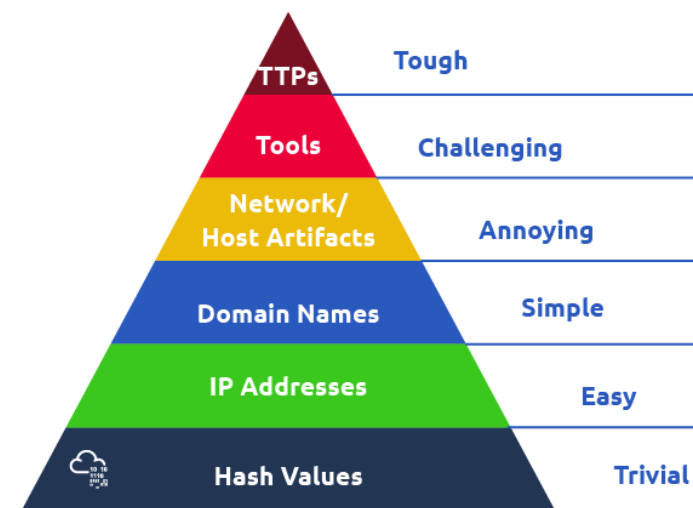
Exemple
Hash, IP, domini
"Hash associat a WannaCry (2017)"
"Coincideix amb campanya activa"
Regla a Wazuh / alerta SOC

Què aporta realment la CTI?

- Entendre **qui** ens ataca i **per què**
 - Actors, motivacions i sectors objectiu
- Saber **com** ho fan
 - Tàctiques, tècniques i procediments (TTP) dels atacants
 - Classificació [MITRE ATT&CK](#)
- Detectar **què** deixen enrere
 - Indicadors de compromís (IoC): hash, IP, domini, URL
- Permet decidir **què fer**
 - Regles al SIEM/EDR per generar alertes o implementar mesures de contenció

Per què la CTI és clau en la detecció d'amenaçes?

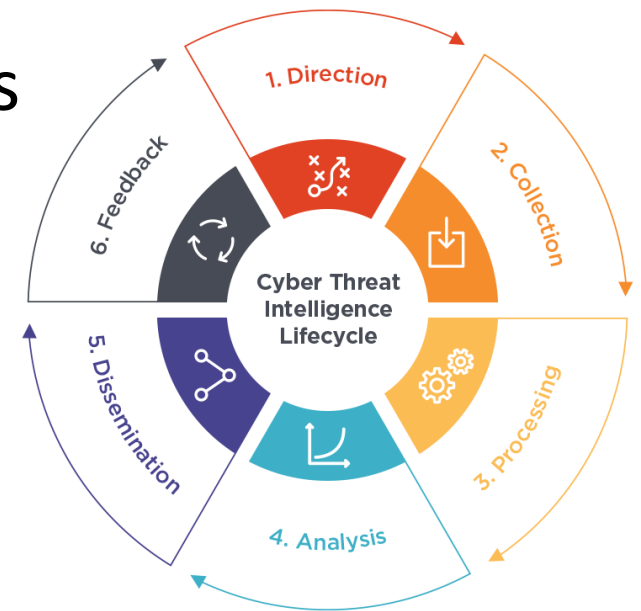
- Permet **prioritzar** perquè no tots els IoC tenen el mateix valor
 - Piràmide del dolor
- Facilita **automatitzar** les deteccions
 - SIEM/XDR
- Ajuda a **reduir els falsos positius**
- Permet **anticipar campanyes** abans que arribin al nostre sector



Font: <https://tryhackme.com/room/pyramidofpainax>

El cicle de vida de la CTI

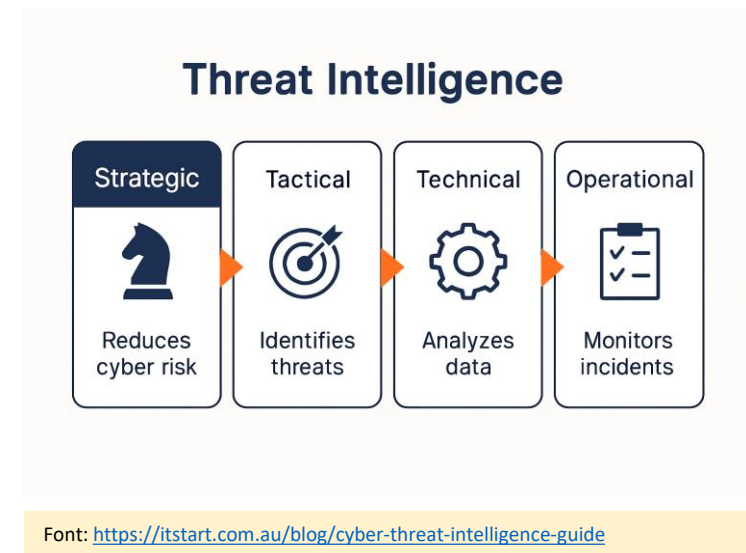
- **Direcció:** definir què necessitem saber
 - "Som objectiu d'atacs de ransomware al nostre sector?"
- **Recollida:** Obtenir dades raw
 - Canals OSINT, logs interns, fòrums, etc.
- **Processament:** normalitzar i estructurar les dades
- **Anàlisi:** extreure'n significat
 - "Aquest patró coincideix amb el grup/actor X"
- **Difusió:** compartir-ho amb qui ho necessiti
- **Retroalimentació:** avaluar si ha servit o reajustar
 - "Calia més detall tècnic?"



Font: <https://www.armorcode.com/learning-center/what-is-threat-intelligenc>

Nivells de CTI

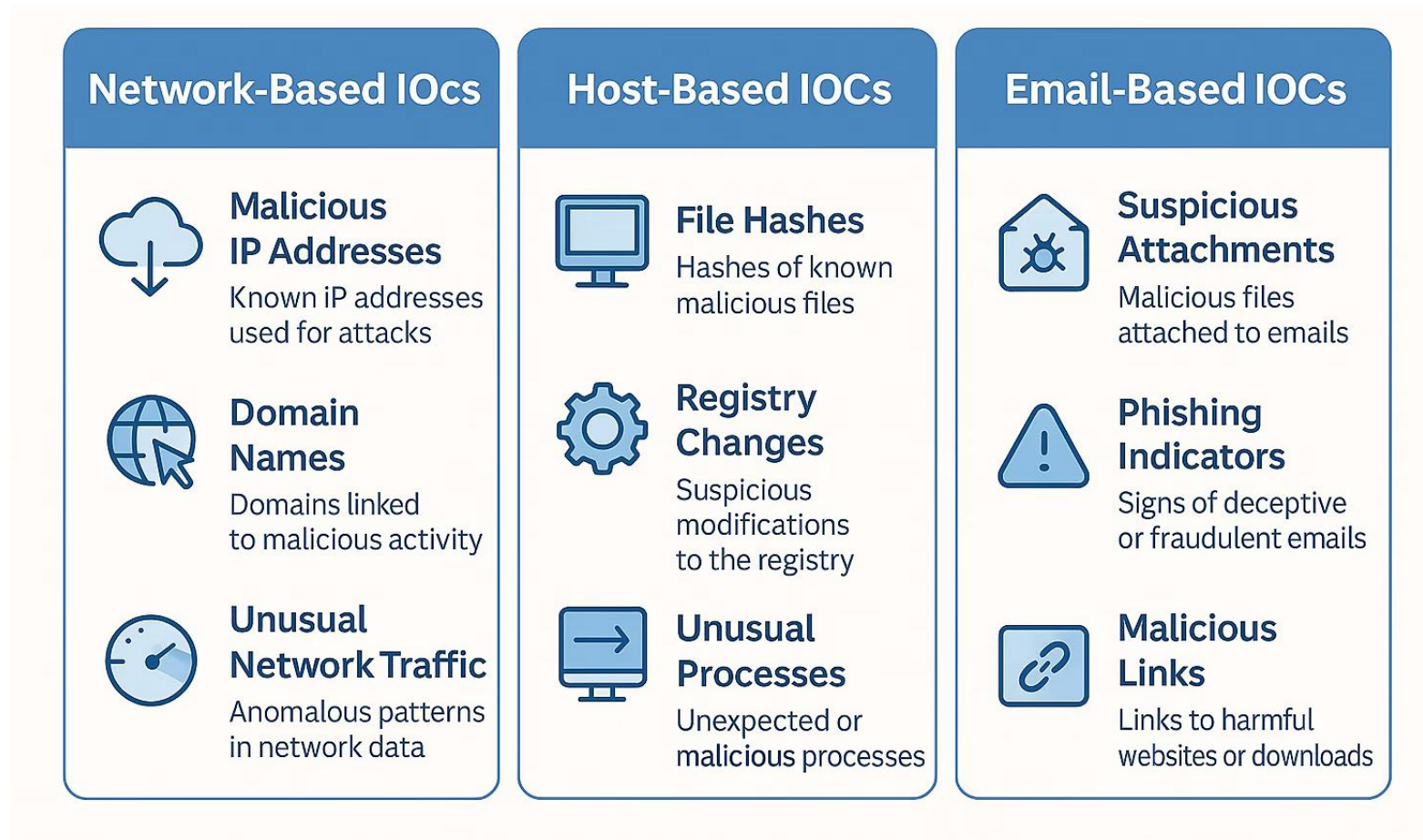
- **Estratègica** (Direcció/CISO; horitzó de mesos o anys)
 - "El sector bancari és objectiu creixent del grup/actor X"
- **Operacional** (Caps de seguretat; setmanes)
 - "Hi ha una campanya activa contra empreses del nostre sector"
- **Tàctica** (Analistes SOC; dies)
 - TTP concrets: "fan servir phishing amb macros"
- **Tècnica** (Eines/SIEM/EDR; hores o minuts)
 - IoC concrets: Hash, IP, domini, URL



Indicadors de compromís (IoC)

- **Evidències observables** que apunten a activitat maliciosa i que permeten detectar, bloquejar o investigar un atac
- Tipus d'IoC habituals:
 - **Hash** (MD5, SHA1, SHA256) d'un fitxer maliciós
 - **IP** d'origen o de C2 (Command & Control)
 - **Domini / URL** utilitzat en phishing, C2 o distribució de malware
 - **Adreça de correu** utilitzada en campanyes de phishing
 - **Claus de registre** modificades per mantenir persistència
 - **Noms de mutex** utilitzats per evitar múltiples execucions (avançat)
- Altres IoC:
 - User-agents, noms de fitxers, processos, etc.

Tipus d'indicadors de compromís



Font: <https://www.paloaltonetworks.co.uk/cyberpedia/indicators-of-compromise-iocs>

Piràmide del dolor

- Proposada per David J. Bianco (2014)
- Mostra el **valor real** dels IoC per a la detecció
 - Com més amunt, **més difícil** és per l'atacant canviar-ho
 - Detectar TTP = **màxim impacte** en la seva operativa
- Ordre de valor
 - Hash: trivial de canviar
 - Adreça IP: fàcil i barat
 - Nom de domini: simple i lleuger cost
 - Artefactes de xarxa/host: molest i cost moderat
 - Eines: desafiant i cost alt
 - TTPs: dur i molt costós, afecta tota la campanya

"Si només detectes hashes, l'atacant et guanya en segons. Si detectes TTPs, li trenques tota la campanya."

Tàctiques, tècniques i procediments (TTP)

- Descriuen **com actua un atacant** (comportament operatiu)
- **Tàctica** → Què vol aconseguir l'atacant? (objectiu)
 - Accés inicial, persistència, moviment lateral
- **Tècnica** → Com ho fa?
 - Phishing amb fitxer adjunt, explotació de vulnerabilitat
- **Procediment** → Implementació concreta
 - "Envia correus amb un fitxer ZIP que conté un fitxer VBS ofuscat"
- Els IoC canvien fàcilment; les TTP són més difícils de modificar

MITRE ATT&CK

- Marc de coneixement que cataloga TTP utilitzades per actors d'amenaques en escenaris reals (attack.mitre.org)
- Actualment inclou:
 - **15 tàctiques** (des de Reconeixement fins a Impacte)
 - Centenars de **tècniques** i sub-tècniques
 - **Exemples reals** d'actors que les utilitzen
 - **Mitigacions i deteccions** recomanades
- És l'estàndard de facto en CTI

"ATT&CK ens permet descriure un atac en un llenguatge comú i basat en comportament."

Exercicis dirigits

- Demo A: Cercar un hash a VirusTotal (www.virustotal.com)
 - SHA256:
275a021bbfb6489e54d471899f7db9d1663fc695ec2fe2a2c4538aabf651fd0f
 - Observar el nombre de motors que el detecten, noms de detecció, etc.
 - Nota: [EICAR](#) no és malware real, és un fitxer de test estàndard de la indústria
- Demo B: Cercar una IP a AbuseIPDB (www.abuseipdb.com)
 - IP:
8.8.8.8
 - Resultat net, 0% confiança en l'abús, adreça reportada
- Demo C: Omplir una fitxa d'loC amb les dades de la Demo A
 - Fitxer EICAR

Fitxa d'IoC EICAR

- **Valor de l'IOC:** 275a021bbfb6489e54d471899f7db9d1663fc695ec2fe2a2c4538aabbf651fd0f
- **Tipus:** Hash (SHA256)
- **Font consultada:** [VirusTotal](#)
- **Resultat:** Net. Fitxer de test, no amenaça real
- **Detalls addicionals:**
 - Nombre de motors que el detecten: 63/65
 - Família de malware / nom de detecció: EICAR Test File
 - Primera vegada vist: 2012-06-14
- **Nivell d'intel·ligència:** Tècnica
- **Conclusió breu:** L'EICAR és un fitxer de test estàndard de la indústria dissenyat perquè els antivirus el detectin sense ser malware real

Treball autònom en parelles



- El treball s'ha de realitzar en **1 únic fitxer PDF per grup** amb:
 - Fitxes completades
- Fitxer sense metadades ;-)
- El nom del fitxer ha de tenir aquest format:
 - `Lab1_grupXX_cognom1_cognom2.pdf`
- L'entrega es fa mitjançant el **Racó**
- Teniu fins a la **mitjanit** del següent dimarts o divendres per entregar

Completar fitxes d'IoC (4 punts)

- IoC #1: Factura en format PDF
 - d33394b2a6d9b4974b544654bd6f7a75
- IoC #2: Mostra de ransomware Wannacry (US-CERT/CISA TA17-132A)
 - 84c82835a5d21bbcf75a61706d8ab549
- IoC #3: Adreça IP
 - 1.1.1.1
- IoC #4: Entrada recent (hash o IP) d'un canal públic de CTI com:
 - <https://threatfox.abuse.ch/browse/>
 - <https://urlhaus.abuse.ch/browse/>
 - <https://ctiwatch.com/iocs>

No descarregueu ni executeu cap fitxer maliciós.

No visiteu cap URL maliciosa.

Piràmide del dolor (1 punt)

- Per a cada indicador, indiqueu de quin tipus és
- Ordeneu-los de l'ordre 1 (trivial de canviar per l'atacant) al 6 (molt costós de canviar; trenca tota l'operació)

Indicador	Tipus	Ordre
275a021bbfb6...651fd0f		
185.220.101.7 (exemple)		
update-msoffice365[.]net (exemple)		
User-Agent "Mozilla/4.0 (compatible; MSIE 6.0)" en trànsit sospitós		
Ús de Cobalt Strike com a framework C2		
Moviment lateral via "pass-the-hash" després de phishing amb macro		

Mapeig a MITRE ATT&CK (Extra)

- Cercar la tàctica i la tècnica (amb el seu identificador) que millor descriu cada escenari
- Escenari 1:
 - "L'atacant envia un correu amb un document Word amb macros que, en obrir-se, executa un script per instal·lar una eina de control remot"
- Escenari 2:
 - "Un cop dins la xarxa, l'atacat utilitza credencials robades per connectar-se per RDP a altres servidors interns"
- Escenari 3:
 - "L'atacant modifica una clau de registre perquè el seu programa s'executi automàticament cada cop que l'equip engega"

OSINT WebQuest (Extra)

- Triar una web de la llista (o una altra que trobeu i justifiqueu)
- Navegueu-la durant 10 minuts i ompliu la fitxa de la pàgina següent

Categoria	Webs
Feeds públics d'IoC	urlhaus.abuse.ch · threatfox.abuse.ch · bazaar.abuse.ch (MalwareBazaar) · otx.alienvault.com (cal registre gratuït)
Eines de reputació/lookup	virustotal.com · abuseipdb.com · shodan.io (cal registre gratuït)
Frameworks de TTP	attack.mitre.org (MITRE ATT&CK) · d3fend.mitre.org
Vulnerabilitats	nvd.nist.gov · cve.org
CERTS oficials	incibe.es/incibe-cert · ccn-cert.cni.es · cisa.gov/news-events/cybersecurity-advisories
Blogs/informes d'actors	ATT&CK Groups (attack.mitre.org/groups) · Google Threat Intelligence blog (cloud.google.com/blog/topics/threat-intelligence)
Comunitat/avisos diaris	isc.sans.edu (SANS Internet Storm Center)

Fitxa OSINT WebQuest

- **Nom i URL**
- **Categoria:** feed IoC, eina de reputació, framework, CERT oficial, informe d'actors
- **Quin tipus d'informació ofereix**
- **A quin nivell de CTI correspon principalment:** tàctica, operacional, estratègica
- **Quin rol de l'organigrama CTI la faria servir més:** analista SOC, threat hunter, CISO, etc.
- **Un exemple concret que hagueu trobat** (una entrada, un informe, un grup APT) en 2 o 3 línies màxim